ACME ENTERPRISE CLOUD SEC

AWS Cloud Security Assessment (Prowler)

Technical Security Assessment, Compliance Audit & Actionable Remediations

TARGET SCOPE / ACCOUNT:	123456789012	AUDIT DATE:	2026-09-28 12:58:56 UTC
CLOUD PROVIDER:	AWS	AUDITING TOOL:	Prowler / Security Scanner
LEAD ASSESSOR:	Lead DevSecOps Team	OVERALL POSTURE:	**Critical Attention Required** (F)

41.7%
SECURITY SCORE

Security Posture Rating: Critical Attention Required (Grade F)
Evaluation completed across **12** automated security checks. Identified **7 failed checks** and **5 compliant checks**. Remediation prioritization should address critical and high findings first to minimize attack surface.

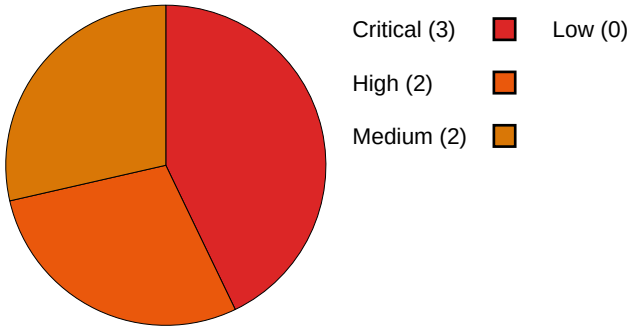
TOTAL CHECKS	PASSED CHECKS	FAILED CHECKS	CRITICAL / HIGH
12	5	7	5

FAILED SEVERITY SPREAD	Critical: 3	High: 2	Medium: 2	Low: 0

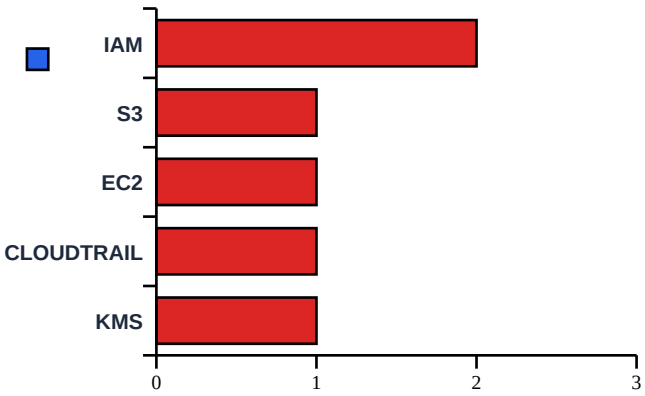
1. Security Visual Analytics & Breakdown

The charts below visualize the risk distribution across severity levels, overall status compliance ratios, and cloud services with the highest number of non-compliant configurations.

Failure Severity Distribution



Top Failing Services (Failure Count)



2. Compliance Framework Alignment

Framework Standard	Total Checks	Passed	Failed	Compliance %	Status Assessment
CIS-2.0	1	**0**	**1**	**0.0%**	**Non-Compliant**
PCI-3.2.1	4	**0**	**4**	**0.0%**	**Non-Compliant**
ISO-27001	2	**0**	**2**	**0.0%**	**Non-Compliant**
CIS-1.5	12	**5**	**7**	**41.7%**	**Non-Compliant**
NIST-800-53	12	**5**	**7**	**41.7%**	**Non-Compliant**

3. Executive Priority Remediation Guide

Severity	Service	Check & Finding Title	Urgent Remediation Action
CRITICAL	IAM	**Ensure MFA is enabled for the 'root' user account** root	Sign in to the AWS Management Console as root, go to IAM > Security Credentials, and enable virtual or hardware MFA.
CRITICAL	S3	**Ensure S3 Buckets do not allow public read/write access** corp-finance-backup	Enable S3 Block Public Access on the bucket and restrict bucket ACL permissions to authorized identities.
HIGH	EC2	**Ensure no Security Groups allow ingress from 0.0.0.0/0 to port 22 (SSH)** sg-09a8b7c6	Restrict inbound SSH access to corporate VPN IP ranges or use AWS Systems Manager Session Manager instead of direct SSH.
HIGH	CLOUDTRAIL	**Ensure CloudTrail is enabled in all regions** security-trail	Update CloudTrail configuration to enable multi-region logging for all global services and regions.
CRITICAL	IAM	**Ensure IAM roles do not allow wildcard '*' in trust relationship** DevOps-Admin-Role	Modify the trust policy of the role to restrict Principal to specific AWS Account IDs or ARNs.

4. Detailed Technical Findings & Remediation

Displaying 12 evaluated checks (Filter: All Checks, Threshold: ALL).

[FAIL] [CRITICAL] **#1. Ensure MFA is enabled for the 'root' user account** `iam_root_mfa_enabled`

Resource:	`arn:aws:iam::123456789012:root`	**Service / Region:**	IAM / global
Details:	Root account does not have MFA (Multi-Factor Authentication) enabled.		
Risk Impact:	Compromise of the root account grants full administrative control over all resources in the AWS environment.		
Remediation:	Sign in to the AWS Management Console as root, go to IAM > Security Credentials, and enable virtual or hardware MFA.		

Fix Command:
```
aws iam create-virtual-mfa-device --virtual-mfa-device-name root-mfa --outfile QRCode.png
```
Ref Doc: https://docs.aws.amazon.com/IAM/latest/UserGuide/id_credentials_mfa_enable-root.html

[FAIL] [CRITICAL] **#2. Ensure S3 Buckets do not allow public read/write access** `s3_bucket_public_access`

Resource:	`arn:aws:s3:::corp-finance-backup`	**Service / Region:**	S3 / us-east-1
Details:	S3 Bucket 'corp-finance-backup' has public read access granted via ACL and policy.		
Risk Impact:	Data breach, accidental exposure of confidential financial records, intellectual property theft.		
Remediation:	Enable S3 Block Public Access on the bucket and restrict bucket ACL permissions to authorized identities.		

Fix Command:
```
aws s3api put-public-access-block --bucket corp-finance-backup --public-access-block-configuration
BlockPublicAcls=true,IgnorePublicAcls=true,BlockPublicPolicy=true,RestrictPublicBuckets=true
```
Ref Doc: https://docs.aws.amazon.com/AmazonS3/latest/userguide/access-control-block-public-access.html

[FAIL] [CRITICAL] **#3. Ensure IAM roles do not allow wildcard '*' in trust relationship** `iam_no_custom_policy_permissive_role_assumption`

Resource:	`arn:aws:iam::123456789012:role/DevOps-Admin-Role`	**Service / Region:**	IAM / global
Details:	Role 'DevOps-Admin-Role' allows sts:AssumeRole from Principal '*'.		
Risk Impact:	Total account takeover by external third parties with no trust boundary.		
Remediation:	Modify the trust policy of the role to restrict Principal to specific AWS Account IDs or ARNs.		

Fix Command:
```
aws iam update-assume-role-policy --role-name DevOps-Admin-Role --policy-document
file://secure-trust-policy.json
```
Ref Doc: https://docs.aws.amazon.com/IAM/latest/UserGuide/id_roles_terms-and-concepts.html

[FAIL] [HIGH] **#4. Ensure no Security Groups allow ingress from 0.0.0.0/0 to port 22 (SSH)** `ec2_securitygroup_allow_ingress_from_internet_to_tcp_port_22`

Resource:	`arn:aws:ec2:us-east-1:123456789012:security-group/sg-09a8b7c6`	**Service / Region:**	EC2 / us-east-1

Details: Security group 'launch-wizard-1' (sg-09a8b7c6) has port 22 open to 0.0.0.0/0.

Risk Impact: Exposure of port 22 increases risk of brute force attacks, credential spraying, and unauthorized server takeover.

Remediation: Restrict inbound SSH access to corporate VPN IP ranges or use AWS Systems Manager Session Manager instead of direct SSH.

Fix Command:
```
aws ec2 revoke-security-group-ingress --group-id sg-09a8b7c6 --protocol tcp --port 22 --cidr 0.0.0.0/0
```

Ref Doc: https://docs.aws.amazon.com/AWSEC2/latest/UserGuide/security-group-rules.html

[FAIL] [HIGH] **#5. Ensure CloudTrail is enabled in all regions** `cloudtrail_multi_region_enabled`

Resource:	`arn:aws:cloudtrail:us-east-1:123456789012:trail/security-trail`	**Service / Region:**	CLOUDTRAIL / us-east-1

Details: CloudTrail 'security-trail' is configured for us-east-1 only, missing activity in other active regions.

Risk Impact: Adversaries can perform unmonitored actions in unlogged regions, hindering forensics and threat detection.

Remediation: Update CloudTrail configuration to enable multi-region logging for all global services and regions.

Fix Command:
```
aws cloudtrail update-trail --name security-trail --is-multi-region-trail
```

Ref Doc: https://docs.aws.amazon.com/awscloudtrail/latest/userguide/receive-cloudtrail-log-files-from-multiple-regions.html

[FAIL] [MEDIUM] **#6. Ensure rotation for customer managed CMKs is enabled** `kms_cmk_rotation_enabled`

Resource:	`arn:aws:kms:us-east-1:123456789012:key/key-abc123`	**Service / Region:**	KMS / us-east-1

Details: KMS Customer Master Key 'key-abc123' does not have automatic yearly rotation enabled.

Risk Impact: Failure to rotate keys expands the blast radius if cryptographic material is compromised.

Remediation: Enable automatic key rotation for the customer managed key in the KMS console or via AWS CLI.

Fix Command:
```
aws kms enable-key-rotation --key-id key-abc123
```

Ref Doc: https://docs.aws.amazon.com/kms/latest/developerguide/rotate-keys.html

[FAIL] [MEDIUM] **#7. Ensure VPC flow logging is enabled in all VPCs** `vpc_flow_logs_enabled`

Resource:	`arn:aws:ec2:us-east-1:123456789012:vpc/vpc-998877`	**Service / Region:**	VPC / us-east-1

Details: VPC 'vpc-998877' (Production-VPC) does not have VPC Flow Logs enabled.

Risk Impact: Without flow logs, security investigations and lateral movement detection are severely impaired.

Remediation: Create flow logs for the VPC to publish traffic data to CloudWatch Logs or an Amazon S3 bucket.

Fix Command:
```
aws ec2 create-flow-logs --resource-type VPC --resource-ids vpc-998877 --traffic-type ALL --log-destination-type s3 --log-destination arn:aws:s3:::corp-vpc-logs
```

Ref Doc: https://docs.aws.amazon.com/vpc/latest/userguide/flow-logs.html

[PASS] [HIGH] **#8. Ensure S3 Buckets have Default Encryption enabled** `s3_bucket_default_encryption`

Resource:	`arn:aws:s3:::app-assets`	**Service / Region:**	S3 / us-east-1

Details: S3 Bucket 'app-assets' has default server-side encryption enabled (AES256).

Risk Impact: Data at rest in S3 without encryption may be exposed if storage media is compromised.

Remediation: Bucket is properly encrypted with AES-256.

Ref Doc: https://docs.aws.amazon.com/AmazonS3/latest/userguide/default-bucket-encryption.html

[PASS] [HIGH] **#9. Ensure RDS database instances have storage encryption enabled** `rds_instance_storage_encrypted`

Resource:	`arn:aws:rds:us-east-1:123456789012:db:db-prod-primary`	**Service / Region:**	RDS / us-east-1

Details: RDS Instance 'db-prod-primary' has storage encryption enabled using KMS key arn:aws:kms:us-east-1:123456789012:key/rds-key.

Risk Impact: Unencrypted database snapshots and volumes risk exposure.

Remediation: Database is properly encrypted with KMS.

Ref Doc: https://docs.aws.amazon.com/AmazonRDS/latest/UserGuide/Overview.Encryption.html

[PASS] [HIGH] **#10. Ensure Amazon GuardDuty is enabled in all active regions** `guardduty_is_enabled`

Resource:	`arn:aws:guardduty:us-east-1:123456789012:detector/det-445566`	**Service / Region:**	GUARDDUTY / us-east-1

Details: Amazon GuardDuty is enabled in region us-east-1 (Detector ID: det-445566).

Risk Impact: Absence of threat detection enables undetected compromise.

Remediation: GuardDuty detector is properly configured and active.

Ref Doc: https://docs.aws.amazon.com/guardduty/latest/ug/guardduty_settingup.html

[PASS] [MEDIUM] **#11. Ensure IAM password policy requires minimum length of 14 or greater** `iam_password_policy_minimum_length_14`

Resource:	`arn:aws:iam::123456789012:password-policy`	**Service / Region:**	IAM / global

Details: IAM password policy requires minimum length of 16 characters.

Risk Impact: Short passwords are susceptible to cracking.

Remediation: Password policy meets and exceeds the recommended length requirement.

Ref Doc: https://docs.aws.amazon.com/IAM/latest/UserGuide/id_credentials_passwords_account-policy.html

[PASS] [LOW] **#12. Ensure S3 Buckets have Object Versioning enabled** `s3_bucket_object_versioning`

Resource:	`arn:aws:s3:::app-assets`	**Service / Region:**	S3 / us-east-1

Details: S3 Bucket 'app-assets' has versioning enabled.

Risk Impact: Accidental deletion or overwriting of files.

Remediation: Versioning is active.

Ref Doc: https://docs.aws.amazon.com/AmazonS3/latest/userguide/Versioning.html